

Network Device Compliance Report

Generated 2026-09-27 13:17

Device Identification

Device (from filename)	cisco_sample.cfg
Hostname	Not present in config
Detected Vendor	Cisco
Privileged Secret Configured	Not present in config
Model / Serial Number	Collected via 'show version' on live device (out of scope for prototype)

Compliance Summary

Framework	CIS
Overall Compliance	35.7% (5/14 controls passed)
Failures by Severity	High: 5 Medium: 4 Low: 0

Compliance Findings

CIS-01	Telnet Disabled	High	FAIL
--------	-----------------	------	------

Description: Telnet transmits credentials and session data in cleartext.
Evidence: transport input telnet ssh
Source: config line
Detected: Enabled
Expected: Telnet must be disabled. SSH should be used for remote administration.
Why it matters: Telnet transmits credentials and session data in cleartext. Anyone on the network path can capture an admin password with a passive sniffer.
Potential attack path: Telnet service exposed on management interface -> Attacker sniffs management VLAN traffic -> Admin credentials captured in cleartext -> Attacker authenticates as administrator -> Full device configuration control obtained
Remediation (vendor-specific):
line vty 0 4
transport input ssh
Meaning: Removes Telnet from the allowed remote-access protocols on the vty lines, forcing SSH.

CIS-02	SSH Version 2 Enforced	High	FAIL
--------	------------------------	------	------

Description: SSHv1 has known cryptographic weaknesses; only SSHv2 should be permitted.
Evidence: ip ssh version 1
Source: config line
Detected: 1
Expected: SSH version 2 must be the only version permitted.
Why it matters: SSHv1 has known cryptographic weaknesses. Only SSHv2 should be permitted.
Potential attack path: SSHv1 supported on management interface -> Attacker performs protocol downgrade or MITM -> Session keys compromised -> Encrypted admin session decrypted -> Unauthorized administrative access
Remediation (vendor-specific):
ip ssh version 2
Meaning: Forces SSH to negotiate only the v2 protocol, eliminating downgrade attacks.

CIS-03	HTTP Management Disabled	Medium	PASS
--------	--------------------------	--------	------

Description: Unencrypted HTTP management exposes credentials and session data.
Evidence: no ip http server
Source: config line
Detected: Disabled
Expected: Unencrypted HTTP management must be disabled.

CIS-04	HTTPS Management Enabled	Medium	FAIL
--------	--------------------------	--------	------

Description: Encrypted management access should be available as the secure alternative to HTTP.

Evidence: No https mgmt enabled configuration detected.

Source: not present in config

Detected: Not configured / not detected in this configuration.

Expected: Encrypted HTTPS management must be available.

Why it matters: Without HTTPS, administrators have no secure alternative to HTTP.

Potential attack path: No encrypted web management -> Admins fall back to HTTP or Telnet -> Credentials exposed -> Device compromise

Remediation (vendor-specific):

ip http secure-server

Meaning: Enables the encrypted web admin interface as the secure replacement for HTTP.

CIS-05	Password Encryption Enabled	High	PASS
--------	-----------------------------	------	------

Description: Locally stored passwords must be encrypted, not stored in plaintext.

Evidence: service password-encryption

Source: config line

Detected: Enabled

Expected: Locally stored passwords must be encrypted, not stored in plaintext.

CIS-06	Minimum Password Length >= 8	Medium	FAIL
--------	------------------------------	--------	------

Description: Weak minimum password length increases brute-force risk.

Evidence: No min password length configuration detected.

Source: not present in config

Detected: Not configured / not detected in this configuration.

Expected: Minimum password length must be at least 8 characters.

Why it matters: Short passwords are vulnerable to brute-force and dictionary attacks.

Potential attack path: Weak password policy -> Remote brute-force attempt -> Account compromised -> Device configuration manipulated

Remediation (vendor-specific):

security passwords min-length 8

Meaning: Sets the minimum required length for local passwords to 8 characters.

CIS-07	Login Banner Configured	Low	PASS
--------	-------------------------	-----	------

Description: A legal/warning banner should be presented before authentication.

Evidence: banner motd ^C Authorized access only. Unauthorized use is prohibited. ^C

Source: config line

Detected: Enabled

Expected: A legal/warning banner must be displayed before authentication.

CIS-08	Session Idle Timeout <= 10 min	Medium	FAIL
--------	--------------------------------	--------	------

Description: Idle admin sessions should time out to reduce hijack risk.

Evidence: exec-timeout 30 0

Source: config line

Detected: 30

Expected: Idle administrative sessions must time out within 10 minutes.

Why it matters: Idle sessions left open can be hijacked by someone with brief access to an unattended terminal.

Potential attack path: Admin leaves session unattended -> Session remains active -> Attacker uses live session -> Configuration changes made as admin

Remediation (vendor-specific):

line vty 0 4

exec-timeout 10 0

Meaning: Terminates an admin session after 10 minutes of inactivity.

CIS-09	Centralized Logging Enabled	High	FAIL
--------	-----------------------------	------	------

Description: Administrative access and events must be logged for audit/forensics.

Evidence: No logging enabled configuration detected.

Source: not present in config

Detected: Not configured / not detected in this configuration.

Expected: Administrative and security events must be sent to a central syslog server.

Why it matters: Without centralized logging, administrative actions and security events are invisible.

Potential attack path: No syslog destination configured -> Attacker actions leave no external trace -> Local logs cleared by attacker -> Incident response impossible

Remediation (vendor-specific):

logging host

logging trap informational

Meaning: Forwards device logs to a central syslog server for audit and forensics.

CIS-10 NTP Configured**Medium****PASS**

Description: Accurate time sync is required for reliable log correlation.

Evidence: ntp server 10.0.0.1

Source: config line

Detected: Enabled

Expected: NTP time synchronization must be configured.

CIS-11 Centralized Authentication (AAA) Configured**Medium****PASS**

Description: Authentication should be centralized (AAA/RADIUS/TACACS+), not local-only.

Evidence: aaa new-model

Source: config line

Detected: Enabled

Expected: Authentication must be centralized via AAA/RADIUS/TACACS+.

CIS-12 Management Access Restricted via ACL**High****FAIL**

Description: Administrative interfaces must be restricted to trusted source addresses.

Evidence: No vty acl applied configuration detected.

Source: not present in config

Detected: Not configured / not detected in this configuration.

Expected: Administrative interfaces must be restricted to trusted source addresses.

Why it matters: Management interfaces open to any source address are reachable from anywhere on the network.

Potential attack path: No ACL restricting management sources -> Attacker reaches management port -> Credential attack / exploit -> Device compromised from inside

Remediation (vendor-specific):

access-list 10 permit

line vty 0 4

access-class 10 in

Meaning: Restricts administrative access to a whitelist of trusted source IP ranges.

CIS-13 No Default/Weak SNMP Community Strings**High****FAIL**

Description: Default community strings (public/private) allow unauthorized SNMP access.

Evidence: snmp-server community public RO

Source: config line

Detected: Enabled

Expected: SNMP community strings must not be the defaults (public/private).

Why it matters: Default SNMP community strings ('public'/'private') are known to every attacker.

Potential attack path: Default SNMP community in use -> Attacker scans with default strings -> Full device inventory disclosed -> Targeted exploitation

Remediation (vendor-specific):

no snmp-server community public

snmp-server community RO

Meaning: Replaces the default 'public'/'private' SNMP community string with a strong custom one.

CIS-14 Account Lockout Policy Configured**Medium****FAIL**

Description: Repeated failed logins should trigger a lockout to slow brute-force attempts.

Evidence: No login lockout configured configuration detected.

Source: not present in config

Detected: Not configured / not detected in this configuration.

Expected: A login lockout policy must be configured.

Why it matters: Without lockout, an attacker can try unlimited passwords without triggering a defensive response.

Potential attack path: No lockout policy -> Unlimited login attempts -> Brute-force succeeds -> Admin account compromised

Remediation (vendor-specific):

login block-for 120 attempts 3 within 60

Meaning: Blocks further login attempts for 120 seconds after 3 failed attempts within 60 seconds.